

Jour 1

Bloc 1

1. Identification de l'entité

HydroRégie – Présentation

HydroRégie est une régie des eaux desservant 450 000 habitants. Elle assure la production, le traitement et la distribution d'eau potable sur son territoire, ainsi que la gestion des infrastructures associées (stations de pompage, usines de traitement, réseau de distribution).

Rattachement sectoriel au sens NIS2

La directive (UE) 2022/2555 classe les secteurs concernés en deux catégories :

- **Annexe I – secteurs hautement critiques** : énergie, transport, banque, infrastructures des marchés financiers, santé, **eau potable**, eaux usées, infrastructures numériques, gestion des services TIC (B2B), administration publique, espace
- **Annexe II – autres secteurs critiques** : services postaux, gestion des déchets, fabrication/production de substances chimiques, industrie alimentaire, fabrication (dispositifs médicaux, électronique, machines...), fournisseurs numériques, recherche

HydroRégie relève du secteur « **Eau potable** », qui figure à l'**annexe I** de la directive : c'est-à-dire un secteur *hautement critique*. C'est un point important à faire ressortir : cela conditionne à la fois le régime de supervision (renforcé) et, combiné à la taille de l'entité, son statut d'entité essentielle plutôt qu'importante.

2. Qualification du statut (essentiel VS important)

La directive NIS2 distingue deux catégories d'entités, selon une combinaison **secteur + taille** :

- Les **entités essentielles** relèvent des secteurs hautement critiques (annexe I) et dépassent les seuils de moyenne entreprise (≥ 50 salariés ou ≥ 10 M€ de chiffre d'affaires/bilan), ou sont désignées comme telles indépendamment de leur taille lorsqu'elles fournissent un service critique dont l'interruption aurait un impact significatif sur la sécurité publique, la santé publique ou la sûreté.
- Les **entités importantes** relèvent soit de l'annexe I sans atteindre les seuils d'entité essentielle, soit de l'annexe II (autres secteurs critiques) au-delà des seuils de petite entreprise.

Application au cas HydroRégie

HydroRégie remplit deux critères cumulatifs qui justifient son statut d'entité essentielle :

1. **Critère sectoriel** : l'eau potable est un secteur hautement critique (annexe I).
2. **Critère de service critique** : HydroRégie dessert 450 000 habitants — une interruption de la distribution d'eau potable aurait un impact direct et significatif sur la santé publique et la sécurité de la population, indépendamment même des seuils de taille classiques.

Ce statut a par ailleurs été **formellement confirmé par l'autorité nationale compétente** (courrier reçu par HydroRégie), ce qui clôt tout doute d'interprétation sur la qualification.

3. Obligations associées au statut d'entité essentielle

a) Gouvernance

- Les **organes de direction** doivent approuver les mesures de gestion des risques en matière de cybersécurité et en superviser la mise en œuvre.
- Ils doivent suivre une **formation** sur les risques cyber, afin d'être en mesure d'identifier les risques et d'évaluer les pratiques de gestion.
- Leur responsabilité peut être engagée en cas de manquement.

b) Mesures de gestion des risques (article 21)

HydroRégie doit mettre en œuvre des mesures **techniques, opérationnelles et organisationnelles** proportionnées au risque, fondées sur une approche « tous risques », couvrant notamment :

- politiques d'analyse des risques et de sécurité des systèmes d'information,
- gestion des incidents,
- continuité d'activité et gestion de crise (sauvegardes, plan de reprise),
- sécurité de la chaîne d'approvisionnement,
- sécurité de l'acquisition, du développement et de la maintenance des systèmes,
- politiques d'évaluation de l'efficacité des mesures,
- pratiques d'hygiène informatique de base et formation à la cybersécurité,
- cryptographie et chiffrement,
- sécurité des ressources humaines, contrôle d'accès, gestion des actifs,

authc) Obligations de notification

En cas d'incident important, HydroRégie doit notifier le CSIRT national/l'autorité compétente selon un calendrier strict :

- **alerte précoce** : sous 24h après avoir eu connaissance de l'incident,
- **notification d'incident** : sous 72h, avec une évaluation initiale (gravité, impact, indicateurs de compromission),
- **rapport final** : sous 1 mois, incluant une description détaillée, la cause probable, les mesures d'atténuation prises.
- authentification à plusieurs facteurs, communications sécurisées.

d) Supervision et sanctions

- En tant qu'entité essentielle, HydroRégie est soumise à un **contrôle proactif** (audits, inspections, demandes d'informations à l'initiative de l'autorité), contrairement aux entités importantes qui font l'objet d'un contrôle réactif (a posteriori, après incident).

- En cas de manquement, des **sanctions administratives** sont prévues, pouvant aller jusqu'à 10 M€ ou 2 % du chiffre d'affaires mondial, selon le montant le plus élevé.

4. Synthèse

Critère	HydroRégie
Secteur	Eau potable (Annexe I – secteur hautement critique)
Service	Distribution d'eau potable pour 450 000 habitants
Statut NIS2	Entité essentielle (confirmé par l'autorité nationale)
Régime de supervision	Contrôle proactif (audits, inspections)
Obligations clés	Gouvernance (art. 20), mesures de gestion des risques (art. 21), notification d'incidents (art. 23)
Délais de notification	Alerte précoce 24h / Notification 72h / Rapport final 1 mois
Vulnérabilité identifiée	Absence de cloisonnement IT/OT — à traiter en priorité (cf. Bloc 2 et 3)
Sanctions encourues	Jusqu'à 10 M€ ou 2 % du CA mondial

Bloc 2

1. Méthodologie

L'analyse s'appuie sur les mesures de gestion des risques prévues à l'**article 21** de la directive NIS2. Pour chaque mesure, on évalue :

- l'**état actuel** chez HydroRégie (déduit du contexte : entité récemment qualifiée, IT/OT non cloisonnés, pas de mention de dispositif de sécurité formalisé),
- le **niveau d'écart** (Fort / Moyen / Faible),
- la **priorité** de traitement (P1 = urgent, P2 = important, P3 = à planifier).

(Dans un cas réel, ces constats viendraient d'entretiens et d'un audit technique. Ici, on part des éléments donnés dans l'énoncé — IT/OT non cloisonnés, entité récemment qualifiée — et on projette un état des lieux réaliste pour une régie des eaux de taille moyenne n'ayant pas encore structuré sa cybersécurité.)

2. Tableau d'analyse d'écart

Mesure (art. 21)	État actuel HydroRégie	Écart	Priorité
Politique d'analyse des risques et de sécurité des SI	Pas de politique formalisée, pas de cartographie des risques	Fort	P1
Gestion des incidents	Pas de procédure documentée, pas de CSIRT interne ni de point de contact désigné	Fort	P1
Continuité d'activité / gestion de crise	Pas de PCA/PRA formalisé pour le SI ; continuité du service d'eau non reliée à un plan cyber	Fort	P1
Sécurité de la chaîne d'approvisionnement	Pas d'évaluation cyber des prestataires/fournisseurs (ex. intégrateurs OT)	Moyenne	P2
Sécurité de l'acquisition, du développement et de la maintenance des SI	Pas de procédure de durcissement ni de gestion des correctifs formalisée sur les systèmes OT	Fort	P1
Évaluation de l'efficacité des mesures	Pas d'audit ni de test d'intrusion réalisé à ce jour	Moyenne	P2
Hygiène informatique de base et formation	Pas de sensibilisation régulière du personnel	Moyenne	P2
Cryptographie et chiffrement	Chiffrement non généralisé sur les échanges et les données sensibles	Moyenne	P2
Sécurité des ressources humaines, contrôle d'accès, gestion des actifs	Pas d'inventaire exhaustif des actifs IT/OT ; droits d'accès non revus régulièrement	Fort	P1
Authentification à plusieurs facteurs, communications sécurisées	MFA non généralisé, notamment sur les accès distants au SI industriel	Fort	P1
Segmentation réseau IT/OT <i>(constat central de l'énoncé)</i>	Système IT et système OT non cloisonnés : un incident sur l'un expose l'autre	Fort	P1

3. Priorisation des écarts

Écarts P1 (urgents — impact direct sur la sécurité du service essentiel) :

- Absence de cloisonnement IT/OT

- Absence de politique de sécurité et de cartographie des risques
- Absence de procédure de gestion des incidents / CSIRT interne
- Absence de PCA/PRA
- Absence de MFA sur les accès sensibles et distants
- Inventaire des actifs et gestion des accès incomplets

Écarts P2 (importants — à traiter à moyen terme) :

- Évaluation cyber des prestataires
- Audits et tests d'intrusion réguliers
- Formation et sensibilisation du personnel
- Généralisation du chiffrement

4. Feuille de route de mise en conformité

#	Action	Priorité	Responsable	Échéance
1	Cartographie des risques et des actifs IT/OT (inventaire exhaustif)	P1	RSSI / DSI	Mois 1
2	Rédaction et validation de la politique de sécurité des SI (approuvée par la direction, art. 20)	P1	Direction générale + RSSI	Mois 1
3	Conception et mise en œuvre de la segmentation réseau IT/OT (<i>livrable détaillé Bloc 3</i>)	P1	DSI / Responsable OT	Mois 1 à 3
4	Mise en place d'une procédure de gestion des incidents + désignation d'un point de contact CSIRT	P1	RSSI	Mois 2
5	Déploiement du MFA sur tous les accès distants et privilégiés	P1	DSI	Mois 2
6	Élaboration d'un PCA/PRA intégrant la continuité du service d'eau potable	P1	RSSI + Responsable exploitation	Mois 2-3
7	Révision et durcissement des droits d'accès (principe du moindre privilège)	P1	DSI	Mois 3
8	Audit de sécurité initial + test d'intrusion (IT et OT)	P2	Prestataire externe mandaté	Mois 3-4
9	Évaluation cyber des fournisseurs et intégrateurs critiques	P2	Achats + RSSI	Mois 4
10	Programme de sensibilisation et formation du personnel	P2	RSSI + RH	Mois 4-5

1	Généralisation du chiffrement sur les	P2	DSI	Mois 5
1	flux et données sensibles			
1	Revue annuelle des mesures et	P2	RSSI	Mois 6 (puis
2	exercice de crise cyber			annuel)

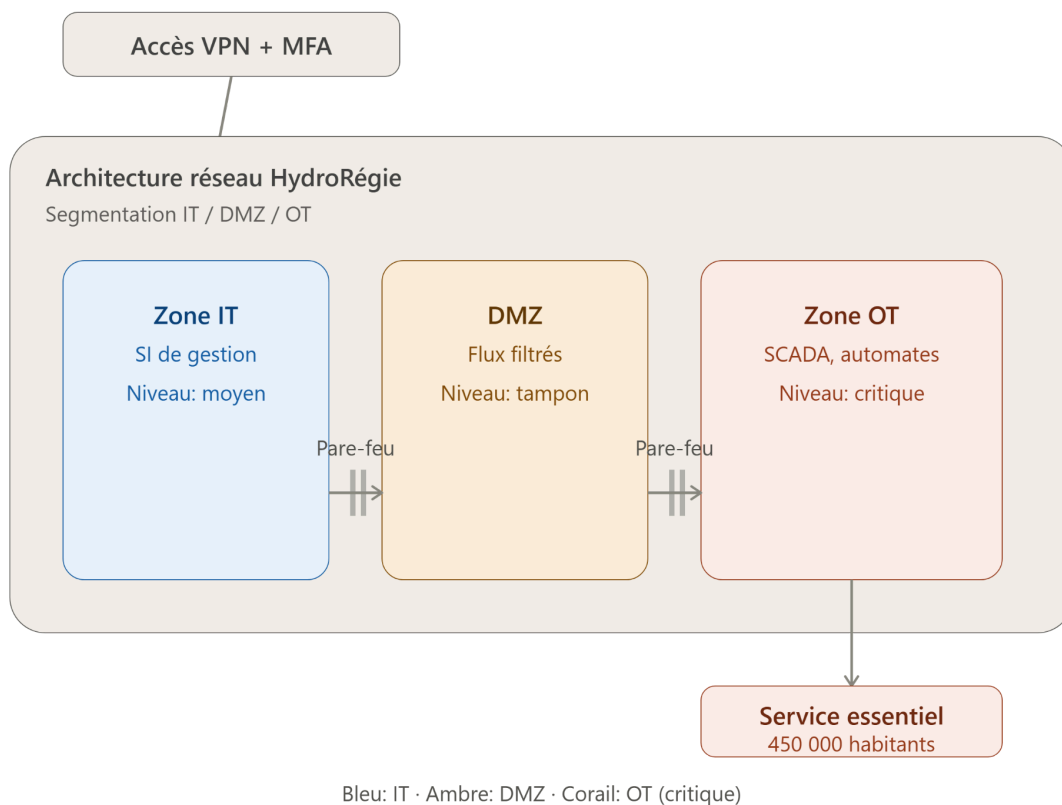
5. Synthèse

La feuille de route s'étale sur **6 mois**, avec une priorité absolue donnée aux 7 premières actions (P1), directement liées à la vulnérabilité structurelle identifiée dans l'énoncé (IT/OT non cloisonnés) et aux exigences minimales de gouvernance et de gestion des risques imposées par l'article 21. Les actions P2 consolident le dispositif une fois le socle de sécurité en place.

Jour 2

Bloc 3

Schéma d'architecture argumenté



3. Justification des choix techniques

Principe général : segmentation en trois zones, avec un principe de flux unidirectionnel autant que possible et un filtrage systématique à chaque frontière.

a) Zone IT (SI de gestion)

- Regroupe la bureautique, les applications métier (facturation, relation abonnés, supervision administrative).
- Niveau de criticité **moyen** : un incident y reste grave (données personnelles des 450 000 abonnés, continuité administrative) mais n'affecte pas directement la production/distribution d'eau si la segmentation tient.
- Accès distant sécurisé par **VPN + authentification à plusieurs facteurs (MFA)**, seul point d'entrée externe autorisé.

b) DMZ (zone tampon IT/OT)

- Héberge les seuls composants devant dialoguer avec les deux mondes : serveur d'historisation des données industrielles (historian), passerelle de supervision, serveur de relais pour la télémétrie.
- Aucun flux direct IT ↔ OT n'est autorisé : tout passage transite et est inspecté dans cette zone.
- Niveau de criticité **transition/tampon** : c'est le point de contrôle qui empêche la propagation d'un incident.

c) Zone OT (système industriel — SCADA, automates, pompes)

- Isolée au maximum : pas d'accès direct depuis l'IT ni depuis l'extérieur.
- Niveau de criticité **fort** : c'est elle qui pilote directement la production et la distribution d'eau potable pour 450 000 habitants — tout incident ici a un impact opérationnel immédiat sur le service essentiel.

d) Pare-feu de segmentation

- Un pare-feu de nouvelle génération (NGFW) filtre chaque frontière IT↔DMZ et DMZ↔OT, avec des règles **par défaut restrictives** (tout ce qui n'est pas explicitement autorisé est bloqué) et une inspection applicative (pas seulement par ports/IP).
- Les règles OT sont particulièrement strictes : seuls les protocoles industriels nécessaires (ex. Modbus, OPC-UA) transitent, uniquement depuis la DMZ, jamais depuis l'IT ou l'extérieur.

e) VLAN

- Chaque zone (IT, DMZ, OT) est déployée sur des **VLAN dédiés et cloisonnés physiquement/logiquement**, évitant qu'une simple erreur de configuration réseau ne recrée un pont entre IT et OT.
- Le réseau OT est en outre subdivisé en sous-VLAN par fonction critique (pompage, traitement, distribution) pour limiter la propagation latérale en cas de compromission.

f) VPN

- Seul canal d'accès distant, réservé aux techniciens et prestataires habilités, avec MFA obligatoire et accès limité dans le temps (comptes à privilèges temporaires plutôt que permanents).
- Aucun accès VPN direct vers la zone OT : un prestataire devant intervenir sur l'OT passe obligatoirement par un poste de rebond situé en DMZ, sous supervision.

g) Continuité du service d'eau potable

- La segmentation garantit qu'un incident cyber sur le SI de gestion (le plus exposé, car connecté à l'extérieur) **ne peut pas se propager** vers le SCADA et les automates qui pilotent réellement la production/distribution d'eau.
- Cette architecture répond directement à la vulnérabilité identifiée dans le Bloc 2 (absence actuelle de cloisonnement) et constitue la mesure technique centrale de la mise en conformité NIS2 pour une infrastructure d'eau potable.

Bloc 4

1. Scénario retenu

Pour rendre la chronologie concrète, je pars du scénario suivant, cohérent avec l'architecture du Bloc 3 : une tentative de compromission provenant de la zone IT, contenue grâce à la segmentation mise en place, mais suffisamment sérieuse pour être qualifiée d'incident important au sens NIS2.

Scénario : un poste de travail du service abonnés d'HydroRégie est compromis via une pièce jointe piégée (phishing). L'attaquant obtient un accès et tente un mouvement latéral vers la DMZ pour atteindre le SCADA. La tentative de connexion vers la DMZ est bloquée et journalisée par le pare-feu de segmentation (Bloc 3), qui déclenche une alerte. L'analyse révèle un rançongiciel actif sur plusieurs postes IT, avec chiffrement de données de facturation abonnés.

2. Chronologie de gestion de crise

Horodatage (J = jour de détection)	Phase	Événement
J, 08h14	Détection	Le SOC/pare-feu de segmentation déclenche une alerte : tentatives de connexion anormales et répétées depuis un poste IT vers la DMZ, sur des ports non autorisés
J, 08h25	Détection	Analyse confirme la présence d'un chiffrement en cours sur plusieurs partages IT (service abonnés) — comportement typique d'un rançongiciel
J, 08h40	Qualification	La cellule de crise cyber est activée. Premier diagnostic : compromission confirmée sur le SI de gestion, aucune trace de compromission sur la DMZ ni sur l'OT à ce stade (grâce au blocage du pare-feu)
J, 09h00	Qualification	Confirmation que l'incident affecte la disponibilité et la confidentialité de données (facturation abonnés) — incident qualifié d' incident important au sens NIS2 (impact opérationnel significatif potentiel + risque de propagation)

J, 09h15	Escalade	Isolement réseau des postes et serveurs IT compromis (coupure des VLAN concernés) ; renforcement temporaire des règles du pare-feu de segmentation IT→DMZ
J, 09h30	Escalade	Information de la direction générale (organe de direction, conformément à l'article 20) et activation de la cellule de crise élargie (RSSI, DSI, responsable exploitation eau, communication)
J, 10h00	Escalade	Vérification approfondie de l'intégrité de la DMZ et de la zone OT : aucune compromission détectée, la production et la distribution d'eau ne sont pas affectées
J, 10h30	Notification	Envoi de l' alerte précoce au CSIRT national/ANSSI (délai réglementaire : 24h — largement respecté ici)
J à J+2	Remédiation	Éradication du rançongiciel, restauration des systèmes IT depuis les sauvegardes saines, changement des identifiants compromis, durcissement des règles d'accès
J+3 (72h)	Notification	Envoi de la notification d'incident complète au CSIRT/autorité compétente, avec évaluation de la gravité et premiers indicateurs de compromission
J+3 à J+30	Remédiation / analyse post-incident	Analyse forensique complète, revue des causes racines (vecteur phishing, absence de sensibilisation), mise à jour de la politique de sécurité, renforcement de la formation du personnel
J+30 (1 mois)	Notification	Envoi du rapport final détaillé au CSIRT/autorité compétente

Point clé à mettre en avant : la segmentation IT/OT conçue au Bloc 3 a joué son rôle — l'incident a été contenu côté IT et n'a jamais atteint le SCADA. C'est l'argument central qui montre que le plan de mise en conformité (Bloc 2 et 3) fonctionne en situation réelle.

3. Notifications réglementaires rédigées

a) Alerte précoce (sous 24h)

Objet : Alerte précoce — Incident de cybersécurité — HydroRégie (entité essentielle, secteur eau potable)

Date/heure de notification : J, 10h30 (incident détecté à 08h14)

Entité notifiante : HydroRégie, régie des eaux, entité essentielle au titre de NIS2, desservant 450 000 habitants

Nature de l'incident : compromission par rançongiciel détectée sur le système d'information de gestion (IT). Tentative de propagation vers le système industriel (OT) bloquée par les mesures de segmentation réseau.

Premiers éléments :

- Périmètre affecté : postes et serveurs du service abonnés (SI de gestion)
- Aucun impact constaté à ce stade sur la production ou la distribution d'eau potable
- Mesures immédiates prises : isolement réseau des systèmes concernés, activation de la cellule de crise

Suite à venir : une notification d'incident complète sera transmise sous 72h conformément à l'article 23 de la directive NIS2.

b) Notification d'incident (sous 72h)

Objet : Notification d'incident — HydroRégie

Date/heure de notification : J+3

Rappel : alerte précoce transmise le J à 10h30

Évaluation de la gravité :

- Incident qualifié d'**incident important** : atteinte à la confidentialité et à la disponibilité de données de facturation abonnés ; risque avéré de propagation vers le système industriel, neutralisé par les mesures de segmentation
- Aucun impact sur la continuité du service d'eau potable

Indicateurs de compromission : vecteur d'entrée identifié comme une pièce jointe piégée (phishing) ; signature du rançongiciel en cours d'analyse ; adresses IP/domaines de commande et contrôle identifiés et bloqués

Mesures prises depuis l'alerte précoce :

- Isolement complet des systèmes IT compromis
- Éradication du rançongiciel et restauration depuis sauvegardes saines
- Renforcement des règles du pare-feu de segmentation IT/DMZ
- Information de l'organe de direction et activation de la cellule de crise élargie

Suite à venir : un rapport final sera transmis sous un mois, incluant l'analyse des causes racines et les mesures correctives durables.

c) Rapport final (sous 1 mois)

Objet : Rapport final d'incident — HydroRégie

Date de notification : J+30

Description détaillée de l'incident : reconstitution complète de la chronologie (cf. section 2), du vecteur d'attaque (phishing ciblant le service abonnés) et du périmètre réellement affecté (SI de gestion uniquement)

Cause probable : absence de sensibilisation suffisante du personnel aux techniques de phishing ; absence de MFA généralisé sur certains comptes du SI de gestion au moment de l'incident

Gravité et impact : impact limité à la disponibilité temporaire du SI de gestion et à la confidentialité de données abonnés ; aucun impact sur le service essentiel de distribution d'eau potable, grâce à l'efficacité de la segmentation réseau IT/OT

Mesures d'atténuation prises :

- Restauration complète des systèmes depuis sauvegardes
- Déploiement du MFA généralisé sur l'ensemble des comptes IT (accélération de l'action prévue en feuille de route, Bloc 2)
- Renforcement du programme de sensibilisation du personnel (formation anti-phishing)
- Révision des règles de filtrage du pare-feu de segmentation
- Exercice de crise programmé pour valider la robustesse du dispositif